

TLP:CLEAR

«Просмотрщик PDF», который живёт в реестре

НТА-рассылка по российским организациям под видом исходящего письма: разбор образца от 1 октября 2026

Рассылка вложением | НТА / JScript | Загрузчик в реестре | Кража паролей браузера

Параметр	Значение
Период событий	1 — 7 октября 2026 (UTC)
Дата анализа	7 октября 2026
Классификация	TLP:CLEAR
Уровень угрозы	СРЕДНИЙ
Тип угрозы	Вредоносное вложение: загрузчик с удалённым управлением и кражей данных браузера
Семейство	Не отнесено ни к одному известному семейству ни одной из трёх проверенных баз образцов
Статус инфраструктуры	Основной управляющий сервер на 7 октября отвечает; два резервных адреса из конфигурации не отвечают

1. Коротко

1 октября 2026 года по российским организациям разошёлся файл с именем «ИСХ № 134ОП-14 от 01.10.2026.hta» — под видом исходящего письма с номером и датой, как их регистрируют в канцеляриях. Антивирусная телеметрия за первые сутки насчитала около тысячи встреч с файлом, то есть рассылка массовая, а не точечная. Образец всплыл в публичных коллекциях 2 октября; ни одна из трёх проверенных нами баз образцов не отнесла его к известному семейству.

Файл — HTML-приложение, которое при открытии рисует интерфейс просмотрщика PDF: тёмная панель с кнопками, как в браузере. Пользователь видит «не открылось», а в это время в его профиле уже записаны ключи реестра, созданы скрытые файлы и поставлена задача планировщика, которая каждые пять минут поднимает загрузчик заново.

Три вещи в этом образце заслуживают отдельного внимания.

- Код хранится в реестре, а не на диске. Следующие стадии записываются в ветку HKCU\Software\RememberMilk строками по две тысячи символов и читаются обратно при каждом запуске. На диске остаются только два коротких скрипта-запуска.
- Первое, что делает загрузчик после закрепления, — достаёт мастер-ключ браузеров на движке Chromium из файла Local State и расшифровывает его средствами Windows. Это ключ ко всем сохранённым паролям и cookies.
- Управляющие серверы прописаны тройкой с резервированием, все три — в одной сети небольшого хостера, на котором годом раньше жили раздачи RAT-инструментов. Команды приходят в XML и исполняются как произвольный код, то есть перед нами не просто стилер, а полноценный удалённый доступ.

2. Как выглядит файл

Расширение .hta означает HTML Application — страницу, которую Windows запускает не в браузере, а в процессе mshta.exe с правами обычной программы. Для получателя это выглядит как документ: имя файла с номером и датой, значок, а после двойного щелчка — окно с тёмной панелью инструментов, стрелками навигации и полем номера страницы. Заголовок окна при этом «Test2»: автор не стал его менять.

Видимая часть страницы — только оформление. Вся полезная нагрузка лежит в восьми скрытых блоках текста, которые на экране не отображаются. Содержимое каждого блока — строки, похожие на идентификаторы GUID: группы шестнадцатеричных цифр через дефис, разделённые запятыми. Девятый скрытый блок содержит короткий декодер.

При загрузке страницы короткий скрипт на VBScript собирает текст всех скрытых блоков, убирает пробелы и переносы и передаёт результат компоненту MSScriptControl как программу на JScript. Декодер читает «GUID»-строки парами символов, переводит каждую пару в байт, пропускает нулевые байты и получает 78 тысяч символов исходного кода. Так файл обходит проверки, которые ищут в HTA подозрительные команды в открытом виде: ни одного вызова системных объектов в тексте страницы нет.

Сам код защищён от беглого чтения: имена всех функций и переменных — случайные наборы из восьми заглавных букв, а примерно сорок процентов объёма занимают пустые комментарии со случайным содержимым, перемежающие каждую строку. После их удаления остаётся 66 тысяч символов ясной структуры.

3. Что происходит на машине

3.1. Закрепление

Загрузчик создаёт в профиле пользователя три дерева каталогов с именами, похожими на следы настоящих программ: RealVNCix\Pointer, CubaseLite\Loop\Unsafe\Time\Scroll\Separate и ObsidianX\Item\Stop\Link\Export\Paste. В них кладутся два скрипта с невинными именами session_history.js и spreadsheet.js, обоим выставляется атрибут «скрытый».

Запуск обеспечивается дважды. В ключе RunOnce создаются записи Blender3D, CloneZillaX и Chromix: каждый загрузчик при очередном запуске перерегистрирует сам себя под своим именем. Параллельно командой schtasks регистрируются три задачи с вложенными именами — FreshDeskер\Ip\Connected\Private (каждые пять минут), \Public и \Previous (каждые пятнадцать), все с ограниченными правами. Вложенное имя — приём, из-за которого задачи не попадают на первый экран планировщика. Всего в двух деревьях каталогов оказывается шесть скриптов-загрузчиков, и удаление части из них не прерывает работу: уцелевшие восстановят остальные.

3.2. Код в реестре

Оба скрипта на диске коротки и одинаковы по смыслу: прочитать из реестра строку, восстановить из неё программу и выполнить. Сама программа лежит в HKCU\Software\RememberMilk и четырёх подключках. Поскольку строковое значение реестра ограничено в длину, код режется на куски по две тысячи символов и записывается под именами вида <имя>_0, <имя>_1 и так далее; при чтении куски склеиваются обратно. Для исполнения используется конструктор Function — аналог eval, который реже привлекает внимание.

Практическое следствие для расследования: антивирусная проверка диска после удаления HTA-файла найдёт два безобидных на вид скрипта по 1 килобайту и ничего больше. Заражение живёт в реестре.

3.3. Кража ключа браузера

Одна из функций загрузчика собирает и выполняет команду PowerShell, которая читает файл Local State из профиля браузера на движке Chromium, берёт из него поле os_crypt.encrypted_key, отбрасывает пятибайтовый префикс и расшифровывает остаток через ProtectedData::Unprotect в контексте текущего пользователя. Результат — мастер-ключ, которым браузер шифрует сохранённые пароли и cookies, — записывается в файл для отправки. Это стандартный и хорошо документированный способ; необычно лишь то, что он выполняется из JScript, а не из скомпилированного стилера.

Рядом лежат функции обхода каталогов с построением имени вида «дата_время_размер_имя» для каждого файла — заготовка под сбор документов по команде с сервера.

3.4. Связь с сервером

Обмен мы наблюдали сами, в собственной песочнице: запросы снимались в момент шифрования, до отправки, поэтому видны полностью, несмотря на TLS.

Сначала машина делает GET на путь /sts. Это проба живости, никаких опознавательных данных в ней нет. Ответ — ровно десять байт, одинаковые и 2, и 7 октября: латиницей написанное русское ругательство. Пустяк, но он кое-что говорит об авторе.

Затем идёт POST на путь /vpr- со случайным суффиксом в 7–12 символов, который клиент выдумывает заново на каждый запрос, — и вот в нём вся суть. Запрос несёт три собственных заголовка: C-I с идентификатором машины (префикс 4tg- и восемь случайных символов), S-K с шестнадцатизначным шестнадцатеричным ключом и R-T со словом conf, то есть «запрашиваю конфигурацию». Тело пустое, тип содержимого заявлен как XML.

Значение S-K оказалось постоянным. Мы запускали образец дважды, на чистой системе, с разными идентификаторами машины — ключ оба раза был один и тот же. Значит, это не ключ сессии, а метка сборки: она переживёт смену адресов и свяжет будущие волны с этой же партией. Для защиты это ценнее любого IP-адреса, и сама тройка заголовков C-I, S-K и R-T в одном запросе в обычном трафике не встречается.

Ответы сервера загрузчик разбирает как XML компонентом MSXML2.DOMDocument, достаёт содержимое нужного тега и передаёт в конструктор Function. Результат возвращается строкой «SUCCESS|...» или «ERROR|...». Иначе говоря, сервер может выполнить на машине произвольный JScript, а кража ключа браузера и перечисление файлов — лишь то, что заготовлено заранее.

4. Инфраструктура

Все три адреса принадлежат одной автономной системе AS197170, сеть зарегистрирована на компанию с адресом на Сейшелах и оборудованием в Нидерландах. На третьем адресе, 45.156.87.3, по данным пассивного DNS в октябре 2025 года размещался домен с названием, прямо отсылающим к RAT-инструменту XWorm, а позже — ещё несколько доменов, встречавшихся в раздачах вредоносного кода. Хостер, таким образом, не случайный.

Основной адрес 45.156.87.120 работает и 7 октября: порт 80 перенаправляет на HTTPS, на 443 отвечает nginx 1.24.0 под Ubuntu, корень отдаёт 404, /sts отвечает, GET на /vpr- отклоняется с кодом 403 — путь принимает только POST. Сертификат самоподписанный, выписан на собственный IP-адрес 24 марта 2026 года: инфраструктура подготовлена за полгода до этой рассылки и, вероятно, обслуживала и более ранние волны. Два резервных адреса из конфигурации, наоборот, не отвечают ни на 80, ни на 443 — проверено с нескольких разных точек выхода.

Другие образцы с обращением к этим адресам в публичных коллекциях не обнаружены. Либо это первая волна с этой инфраструктурой, либо прежние волны не попали в поле зрения.

5. Что показала детонация

Образец мы запускали в собственной изолированной среде, весь исходящий трафик которой уходил через анонимизирующую сеть, чтобы не раскрыть, откуда ведётся наблюдение.

Первая попытка кончилась ничем: окно с ошибкой сценария и больше ничего. Причина оказалась поучительной. Компонент MSScriptControl, через который файл исполняет свою полезную нагрузку, существует только в 32-битном виде. Песочница по умолчанию запускает 64-битную версию mshta, и в ней вызов компонента падает. А когда получатель открывает вложение двойным щелчком, Windows запускает 32-битную версию — и всё работает. Отсюда практический вывод: проверка такого файла в 64-битном обработчике даёт ложный вывод «ничего не происходит». Мы добавили запуск через 32-битный обработчик, и образец заработал.

Дальше всё пошло по описанной схеме: три задачи в планировщике, шесть скриптов-загрузчиков, две попытки достать мастер-ключ — отдельно для Chrome и отдельно для Edge, — и один обмен с сервером. Сервер ответил: сорок байт на запрос конфигурации.

А вот дальше не произошло ничего. За семь минут наблюдения загрузчик не записал в реестр ни одного модуля, не создал новых файлов и больше к серверу не обращался. То есть управляющий узел жив и отвечает, но нашей машине работы не выдал. Почему — достоверно сказать нельзя. Возможны два объяснения: оператор отбирает жертв по происхождению трафика, а мы пришли из анонимизирующей сети, а не из российской корпоративной почты; либо выдача модулей в этой волне уже свёрнута. Мы не можем отличить одно от другого и не станем выдавать догадку за факт.

6. Индикаторы

Адреса и ключи реестра приведены в том виде, в каком они извлечены из кода. Для блокировки годятся адреса серверов и хеши файла; ключи реестра, имена задач и путей — для поиска уже заражённых машин.

Тип	Значение	Примечание
Управляющий сервер	45[.]156[.]87[.]120:443	Основной; на 7 октября отвечает. nginx 1.24.0 (Ubuntu), самоподписанный сертификат CN=45[.]156[.]87[.]120, выписан 24.03.2026
Управляющий сервер	176[.]65[.]132[.]239:443	Резервный из конфигурации; на 7 октября соединение не устанавливается
Управляющий сервер	45[.]156[.]87[.]3:443	Резервный; не отвечает. В 2025 году адрес обслуживал домены раздачи RAT
URL	hxxps://45[.]156[.]87[.]120/sts	Проба живости. Ответ — постоянные 10 байт
Шаблон URL	hxxps://<сервер>/vpr-<7–12 символов>	POST за конфигурацией; суффикс генерируется клиентом заново на каждый запрос
Заголовок HTTP	C-I: 4tg-XXXXXXXXX	Идентификатор заражённой машины
Заголовок HTTP	S-K: D9F72A4E6A3D4FA6	Постоянная величина: одинакова в разных заражениях — ключ сборки, а не сессии

TLP:CLEAR

Заголовок HTTP	R-T: conf	Тип запроса. Тройка C-I + S-K + R-T в одном POST — основной сетевой признак
User-Agent	Mozilla/4.0 (compatible; Win32; WinHttp.WinHttpRequest.5)	Значение по умолчанию СОМ-объекта WinHttpRequest
SHA-256	1d79ab0c2d0183fcfa2772b008c4f146ec0c83000865a1bb2be2c8209d0abb88	HTA-файл, 190 084 байта
MD5	66c671e994bd7d61a1b1811ed46a5dbe	То же
Имя файла	ИСХ № 134ОП-14 от 01.10.2026.hta	Приманка под исходящее письмо организации
Ключ реестра	HKCU\Software\RememberMilk	Хранилище следующих стадий, строки по 2000 символов
Ключ реестра	HKCU\...\CurrentVersion\RunOnce\Blender3D	Автозапуск: wscript.exe ... \session_history.js
Ключ реестра	HKCU\...\CurrentVersion\RunOnce\CloneZillaX	Автозапуск: wscript.exe ... \backup_archive.js
Ключ реестра	HKCU\...\CurrentVersion\RunOnce\Chromix	Автозапуск: wscript.exe ... \email_list.js
Задача планировщика	FreshDesker\lp\Connected\Private	Каждые 5 минут: wscript.exe ... \ObsidianX\...\spreadsheet.js
Задача планировщика	FreshDesker\lp\Connected\Public	Каждые 15 минут: wscript.exe ... \ObsidianX\...\download_queue.js
Задача планировщика	FreshDesker\lp\Connected\Previous	Каждые 15 минут: wscript.exe ... \ObsidianX\...\screen_map.js
Путь	%LOCALAPPDATA%\CubaseLite\Loop\Unsafe\...	Скрытые загрузки: session_history.js, backup_archive.js, email_list.js
Путь	%LOCALAPPDATA%\ObsidianX\Item\Stop\...	Скрытые загрузки: spreadsheet.js, download_queue.js, screen_map.js
Путь	%LOCALAPPDATA%\RealVNCix\Pointer\	Рабочий каталог загрузчика

SHA-256 загрузчика	a690ceebe4ed804fe3217a25b4ed94786d58d7ee4024f36887aa620ba793be	backup_archive.js, 2843 байта
SHA-256 загрузчика	d3b6c64efadcc722d1feabb677f0e11001901e97f0be35c8fe12731a6dc0ab70	email_list.js, 2898 байт
SHA-256 загрузчика	f43139ef9d88ede77a4bc9b2d44eb442665d3da256077e76dab4b610d664b3ad	session_history.js, 3534 байта

7. Что искать на своих машинах

- Процесс wscript.exe, запущенный из записи RunOnce или из задачи планировщика, со скриптом в %LOCALAPPDATA% в каталоге с «программным» именем. В нормальной жизни так не бывает.
- Задача планировщика с вложенным путём в имени и интервалом в пять минут, запускающая wscript.exe.
- Ветка HKCU\Software\RememberMilk и любые ключи, под которыми лежат десятки строковых значений с именами <имя>_0, _1, _2 — это и есть код в реестре.
- Запуск PowerShell из-под wscript.exe или mshta.exe с чтением файла Local State из профиля браузера.
- Создание объекта MSScriptControl.ScriptControl процессом mshta.exe. Компонент давно не используется легитимными приложениями.
- На периметре: соединения на 443-й порт к трём адресам из таблицы, запросы к путям /sts и /vpr-.
- На почтовом шлюзе: вложения .hta стоит блокировать безусловно. Применений этому формату в деловой переписке нет.

8. Чего мы не знаем

Мы не видели письмо, в котором приходил файл. Имя файла указывает на предлог «исходящее письмо организации», но текст сопроводительного сообщения, адрес отправителя и список получателей нам неизвестны; оценка «массовая рассылка» опирается на счётчик антивирусной телеметрии, а не на собственные наблюдения.

Мы не получили модулей второй ступени. Сервер отвечает, но на запрос конфигурации выдал сорок байт и ничего больше; в реестр и на диск при этом ничего не легло. Содержимое самих сорока байт прочитать не удалось — инструмент перехвата обрезает запись на двух сотнях байт, а заголовки ответа этот предел исчерпывают, и в памяти процесса ответ не сохранился. Поэтому мы знаем, что загрузчик умеет и как он спрашивает сервер, но не знаем, что именно сервер отвечает тем, кого считает подходящей жертвой.

Семейство и оператор не установлены. Сочетание признаков — HTA с кодом в «GUID»-строках, хранение стадий в реестре, вложенные имена задач, кража ключа Chromium из JScript — характерно для одной линии коммерческих JScript-загрузчиков, но имени, под которым её принято описывать, мы называть не беремся без сопоставления с большим числом образцов.

TLP:CLEAR — Этот документ может распространяться без ограничений.